

飞书 AI 校园挑战赛 · 决赛 2026

A2A-Token-System

面向多 Agent 协作的零信任授权平台

LEAD

陈奕燊

IdP · OPA

ENGINEER

周展鹏

Gateway · Web · Audit

ENGINEER

金梓墨

Agents · SDK · 飞书接入

HDU · <https://github.com/Woor3x/Agent-Token>

| 从问题到答案·六章节

01 背景 — AI Agent 时代的授权困局 ~35s

02 问题分析 — OAuth 在 A2A 的失能 ~45s

03 解决方案 — A2A-Token-System ~30s

04 整体设计 — 系统架构 ~50s

05 模块细分 — IdP · OPA · GW · Audit · Agents ~190s

06 创新 · 对比 · 价值 · 谢幕 ~105s

TOTAL $\approx$ 490s · 8 min (OPA + Gateway 拆开后 +15s · 压缩 P13 谢幕缓冲)

| AI Agent 正以用户身份访问企业数据

↑ 3×

2024-2026 企业 Agent 部署量增速

Gartner / IDC 多份报告

A2A

Agent-to-Agent 调用成主导模式

编排者 + 多执行者拓扑普及

∞

委托深度 = 攻击面平方级膨胀

单 Agent 失陷波及全链

"AI Agent 需以用户身份操作企业资源 — 但 OAuth 没有为机器代机器的细粒度委托而设计。"

| 现有 OAuth 在 A2A 场景下的四个失能

FAILURE 01 · 信任传递断裂

无机器代机器细粒度授权

OAuth access_token 只表达"用户 → 客户端"；缺失"用户 → Agent A → Agent B"链上身份与上下文，下游无法判定真实调用者。

FAILURE 02 · 时效失控

长生命期 token 与持有者凭证

小时级 access_token + Bearer 模式，一旦泄露窗口期内可重放、横向渗透；缺乏 PoP (Proof-of-Possession) 绑定。

FAILURE 03 · 委托不可追

链路审计缺失

无标准化的委托链记录字段 (actor / chain / trace)，事后追责只能依赖应用层日志，跨 Agent 关联困难。

FAILURE 04 · 权限放大

scope 静态绑定 ≠ 任务最小

scope 在 consent 时一次绑定，无法按"本次任务实际所需"动态收敛，给出的是"上限"而非"所需"。

A2A-Token-System · 三支柱回应四失能

以 *IETF 标准协议* 为底座 · *最小权限交集* 为分配策略 · *全链审计* 为追责保证 — 构建零信任 A2A 授权平台。

PILLAR I

标准协议栈

RFC 8693 委托链 · RFC 9449 DPoP 持有者证明 · RFC 7523 客户端断言 · RFC 7636 PKCE — 不造轮子，全栈复用。

→ 解 FAILURE 01·02

PILLAR II

最小权限交集

每次签发计算 `callee_caps` $\cap$ `user_perms` $\cap$ `requested_scope` · 120s 一次性令牌 · 6 维即时撤销。

→ 解 FAILURE 04

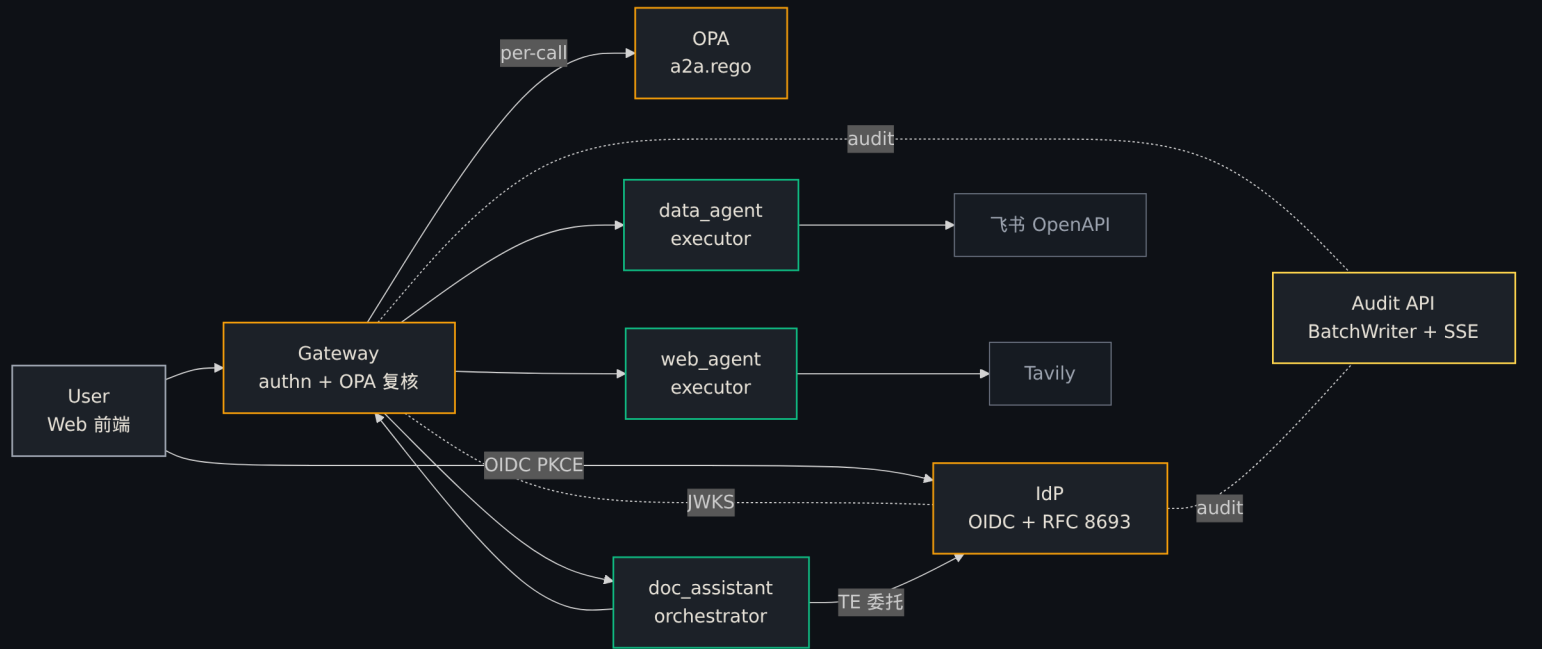
PILLAR III

全链审计

W3C traceparent 全链传播 · Audit 记录 `decision/reasons/jti/jkt` · Gateway × OPA 每调用复核。

→ 解 FAILURE 03

系统架构 — 安全 / 编排 / 执行 三平面



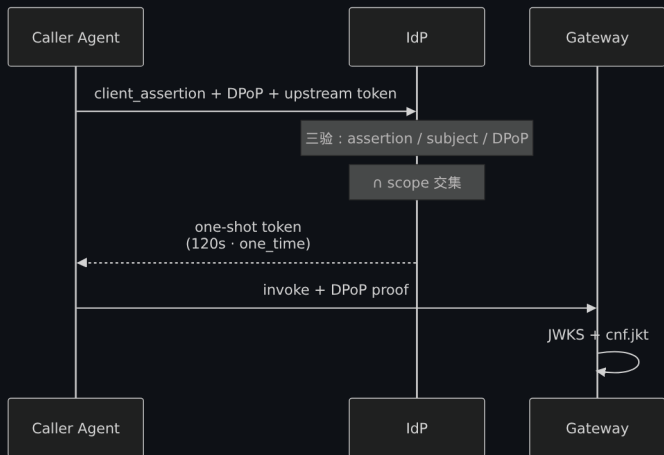
SEC IdP · GW · OPA

AUDIT 不可篡改之外，多维查询

AI orchestrator + executor 互斥

EXT 飞书 · Tavily

IdP — Token Exchange 三验签发



RFC 8693 · TOKEN EXCHANGE

三大输入 · 三大验证

client_assertion 默认 60s (IdP 接受 $\leq 600s$)

DPoP proof 防盗用 · subject token 表达原始用户身份

EFFECTIVE SCOPE

effective = callee_caps

n user_perms

n requested_scope

三集合任一为空 → 拒签。永不"宽给"。

120s · one_time

sub_jti 唯一

cnf.jkt 绑定

| OPA — Policy as Code 决策与代码解耦

REGO · 10 RULES · ALL AND

- ① token_valid — JWT 签名/exp/aud 合法
- ② one_time_declared — 必须 one_time=true
- ③ audience_match — aud == 被调端
- ④ scope_covers — 请求 $\subseteq$ token scope
- ⑤ executor_valid — callee role=executor
- ⑥ delegation_accepted — act 链合法
- ⑦ delegation_depth_ok — 链深 $\leq$ 上限
- ⑧ not_revoked — 6 维撤销集均未命中
- ⑨ dpop_bound — cnf.jkt 与 DPoP 匹配
- ⑩ context_ok — time/IP/purpose 约束

infra/opa/policies/a2a.rego · 206 行

DECISION OUTPUT

```
{  
  allow: bool,  
  reasons: ["rule_id", ...],  
  jti, jkt, scope, sub  
}
```

decision + reasons 双字段 → 拒绝即可解释

WHY OPA

业界**通用策略引擎** · 直接复用不重造 · 策略文件
版本化 · 单元测试与代码解耦。

| Gateway — per-call 复核 · 三道关纵深

AUTHN MIDDLEWARE · 调用流水线

- ① JWKS 公钥验签 RFC 7517
- ② DPoP proof 校验 RFC 9449
- ③ cnf.jkt ↔ DPoP 公钥 thumbprint
- ④ 4 维 revocation 检查 (jti/sub/agent/chain)
- ⑤ 构造 OPA input · 调 decide
- ⑥ allow ? 转发 : 403 + reasons
- ⑦ 异步写 Audit (decision/jti/jkt)

infra/gateway/middleware/authn.py

GATE I · IdP 签发关

事前 ABAC : subject / agent / action / context + scope n 计算。

GATE II · Gateway × OPA 关

per-call JWKS + DPoP + Rego 10 条全 AND — 每次调用必经此关。

GATE III · Capability 匹配关

Agent 启动期注册 + 调用前 `capability.find()` 二次校验。

RFC 9449 · DPoP

每调用带 ephemeral JWS proof · 持有者证明 ↔ Bearer — token 泄露不可重放。

单点收敛

Agent 仅信 Gateway · 业务无需懂 RFC · 策略变更只动 Rego。

Audit · 撤销 · 生态适配

6 维即时撤销 · revocation_sets

```
KEY_MAP = {  
  "jti": "单 token 维度",  
  "sub": "用户维度",  
  "agent": "Agent 维度",  
  "trace": "调用链维度",  
  "plan": "任务计划维度",  
  "chain": "委托链维度",  
}  
# Redis Pub/Sub → 集群秒级生效
```

AUDIT · BatchWriter + SSE

`asyncio.Queue` → SQLite WAL 批写

SSE 实时推送 · 多维查询

字段：decision · reasons · jti · jkt · scope · sub

W3C traceparent 全链 header 传播

SDK · 3 框架 ADAPTER

- `agent_token_sdk/adapters/`
- LangChain · `StructuredTool`
- LangGraph · 节点级 invoke

TEST · 77 / 77

77 SDK 单元 + 集成测试用例 · 100% pass
覆盖 TE / DPoP / capability / adapter / fault injection

Agents — orchestrator · executor 严格分离

ORCHESTRATOR

doc_assistant

LangGraph DAG · LLM JSON mode + 规则
回退

`_topo_layers` 拓扑分层
`asyncio.gather` 同层并发
`validate_dag()` 失败 LLM 重试

EXECUTOR

data_agent

Intent 路由 (regex 匹配)
飞书 OpenAPI : bitable / docx / contact /
calendar / drive
Prompt Injection 清洗
无 LLM · 纯确定性

EXECUTOR

web_agent

`web.search` · Tavily 检索
`web.fetch` · HTML 提取 + LLM 摘要
URL allowlist 限制
速率限制 + 安全提取

SOD · SEPARATION OF DUTIES

`@field_validator("role")` 启动期强制 orchestrator XOR executor ,
互斥防越权升级。

SHARED SDK

屏蔽 RFC 8693 TE + RFC 9449 DPoP + W3C traceparent ·
`capability.find()` 调用前匹配。

AI 在产品中 · 与在开发中

FEATURE SIDE · 产品中的 AI

① 结构化 DAG 编排

LLM 产 JSON 计划 → `validate_dag()` 拒收非法结构 → LLM 重试 / 规则回退。

② JSON Mode + 后置 Schema

`response_format=json_object` + Schema validator 双层防线，抑制幻觉跑偏。

③ AI 与安全完全隔离

AI 路径无授权决策权 · 故障不污染 IdP/Gateway/OPA · agents 只做 capability 匹配。

④ 用户描述目标即完成

ENGINEERING SIDE · 开发中的 AI

① 需求 → 方案

AI 头脑风暴备选 → 人工拍板 — brainstorming skill 落地。

② 架构 → 设计文档

AI 写 spec 作为编码“合同” · 二次审核去歧义。

③ 编码 Plan-Act

先出 plan 拆任务，再 Act 执行 · subagent-driven-development workflow。

④ 测试与审计

AI 定位根因 → 人工确认提交 · 代码核实贯穿全程。

| 差异化定位 — 五位一体

方案	定位	差异
draft-aap-oauth-profile	IETF 组合规范	草案 · 无实现
permit.io	决策判定 PDP	不解决 token 委托
Okta for AI Agents	闭源 SaaS	强绑定 · 国内合规风险
Veto	单 Agent 策略	无 A2A 委托
Portkey Agent Gateway	LLM 流量代理	只记录不裁决
OPA	通用策略引擎	直接复用，不重造

FIVE PILLARS

- ① 协议标准 — IETF 全栈
- ② 零信任 — DPoP + cnf.jkt
- ③ 最小权限 — 三集合 n
- ④ 全链审计 — traceparent + 6 维撤销
- ⑤ 多框架 — LangChain / LangGraph / AutoGen

LANDING VALUE

解决权限失控 · 构建可信链路 · 满足合规审计 · 提升业务效率

END · Q&A

Thank *You*

期待你的提问

LEAD

陈奕燊

IdP · OPA · 早期 AuditApi

ENGINEER

周展鹏

Gateway · Web · Audit 测试

ENGINEER

金梓墨

Agents · SDK · 飞书接入

<https://github.com/Woor3x/Agent-Token>

120s 委托 · 6 维撤销 · 3 道关 · 6 RFC · 77 SDK 测试 100% pass